DealSure — ออกแบบระบบใหม่ v2

Oct 28, 2026 · @Biw

0. ข้อมูลพอไหม

ข้อมูลพอสำหรับออกแบบระบบ ส่วนที่ยังไม่รู้ทำเป็นสมมติฐานไว้ ทีมต้องยืนยันหรือถาม mentor

ยังไม่รู้	สมมติว่า
ธนาคารเรียก API ตำรวจ / AOC 1441 / CFR ได้ทันทีตอนทำรายการไหม	เรียกได้ แต่ตอบช้าและบางครั้งล่ม จึงต้องมี cache
"พักเงินไว้ในบัญชีผู้ซื้อ" ถูกนับเป็น escrow ตามกฎหมายไหม	ไม่นับ เพราะเงินยังอยู่ในบัญชีผู้ซื้อ (ต้องถาม mentor)
ข้อมูลภายในของธนาคารมีอะไรบ้าง	มีแค่ข้อมูลพื้นฐาน: KYC, อายุบัญชี, ประวัติธุรกรรม, อุปกรณ์
ขนส่งเปิด API ให้ตรวจเลขพัสดุไหม	มี (ใน demo ใช้แบบจำลอง)

สิ่งที่ไฟล์ pitch 3 นาทีบังคับ และกระทบการออกแบบ

- เนื้อหาต้องครบ 3 เรื่อง: ปัญหาและกลุ่มเป้าหมาย (first jobber) → solution และวิธีทำงาน → คุณค่าและผลกระทบ (กันโกง)
- ส่งเป็นไฟล์ PowerPoint .ppt ภายใน 30 ต.ค. 2026 ชื่อไฟล์ `ลำดับ_ชื่อทีม_Track_3MinPitch` ส่งแล้วแก้ไม่ได้ วัน pitch คือ 7 พ.ย. 2026
- ห้ามใส่ชื่อหรือโลโก้ KBank / KBTG / K PLUS ในตัวผลิตภัณฑ์, prototype และ demo ชื่อฟีเจอร์จึงต้องเป็นชื่อกลาง ๆ
- demo ขึ้นออนไลน์ได้ถ้าจำกัดสิทธิ์เข้าถึง และปิดทันทีหลังแข่ง
- ต้องตรวจความปลอดภัยของโค้ดที่ AI เขียน

1. แนวคิดใหม่

ระบบสร้างดีลที่ธนาคารรับรอง สำหรับซื้อขายกับคนแปลกหน้าในโซเชียล ผู้ขายสร้าง QR ที่ธนาคารเซ็นรับรอง ผู้ซื้อสแกนด้วยแอปธนาคารที่มีอยู่แล้ว แล้วเห็นตัวตนจริงและระดับความเสี่ยงของผู้ขายก่อนจ่ายเงิน ดีลเสี่ยงต่ำได้รับเงินทันที ดีลเสี่ยงสูงพักเงินไว้ในบัญชีผู้ซื้อจนเลขพัสดุตรวจผ่าน ทุกขั้นถูกบันทึกเป็นหลักฐานที่แก้ไม่ได้ และส่งต่อตำรวจได้ทันทีถ้ามีปัญหา

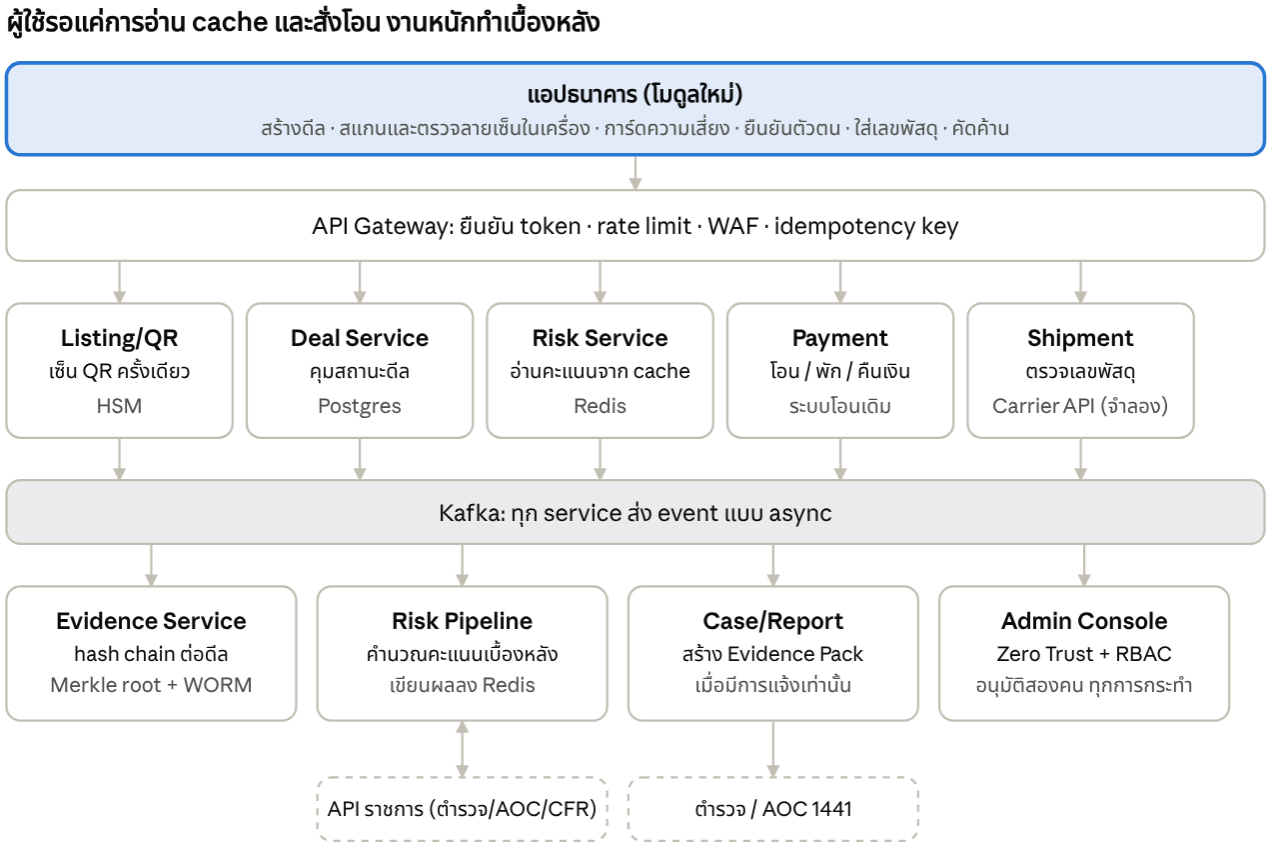
หลักการ 6 ข้อที่ตัดสินใจแล้ว

1. เฟส 1 รองรับเฉพาะลูกค้าธนาคารเดียวกันทั้งสองฝั่ง (on-us) แล้วค่อยขยายข้ามธนาคารในเฟส 2
2. ฝังอยู่ในแอปธนาคาร ไม่ใช่แอปแยก ผู้ซื้อใช้ปุ่มสแกนเดิม ผู้ขายได้ปุ่ม "สร้างดีล" เพิ่ม

3. ธนาคารไม่ตัดสินข้อพิพาท ใช้กฎที่เครื่องตรวจได้ ถ้าตรวจไม่ได้ก็ส่งหลักฐานต่อหน่วยงานรัฐ
4. พักเงินเฉพาะดีลเสี่ยงสูงตาม threshold
5. QR สองชั้น: QR ผู้ขายหรือสินค้าใช้ซ้ำได้ ส่วนดีลแต่ละรายการสร้างใหม่ทุกครั้งที่มีคนสแกน
6. ตรวจทั้งสองฝั่งแต่ใช้ผลต่างกัน: ผู้ขายได้คะแนนความเสี่ยงที่ผู้ซื้อเห็น ส่วนผู้ซื้อแค่ผ่านด่านผ่าน/ไม่ผ่าน และผลไม่แสดงให้ผู้ขาย

2. System Architecture

ระบบเป็นโมดูลในแอปธนาคาร + service เล็ก ๆ ที่เสียบเข้ากับระบบโอนเดิม งานหนักทั้งหมดทำเบื้องหลัง ผู้ใช้รอแค่การอ่าน cache และสั่งโอน



system architecture · แอป → gateway → 5 service → event bus → งานเบื้องหลัง

กล่องเส้นประคือหน่วยงานภายนอก แถวบนสุดถึง 5 service คือเส้นทางที่ผู้ใช้รอ ส่วนใต้ Kafka ทำงานเบื้องหลังทั้งหมด

หน้าที่ของแต่ละส่วน

ส่วน	ทำอะไร	ทำไมแยกออกมา
Listing/QR Service	สร้างและเซ็น QR ผู้ขายหรือสินค้าด้วย HSM ครั้งเดียว เก็บสถานะ (ขายแล้ว/ยกเลิก)	เซ็นเป็นงานแพง ทำครั้งเดียวต่อสินค้า

ส่วน	ทำอะไร	ทำไมแยกออกมา
Deal Service	สร้างดีลเมื่อมีคนสแกน คุมสถานะดีล (state machine) และนาฬิกาหมดเวลา	หัวใจของ flow ต้องตรวจสอบย้อนหลังได้
Risk Service	อ่านคะแนนที่คำนวณไว้แล้วจาก cache คืนผลภายในไม่กี่มิลลิวินาที	ไม่คำนวณตอนผู้ใช้รอ
Risk Feature Pipeline	คำนวณคะแนนเบื้องหลังจากข้อมูลบัญชี, graph การโอน และผลจาก API ภายนอก	งานหนักทำนอกเส้นทางที่ผู้ใช้รอ
External Check Adapter	เรียก API ตำรวจ/AOC/CFR ด้วย OAuth + mTLS, cache ผล, ตัดวงจรเมื่อปลายทางล่ม	ปลายทางล่ม ระบบเราต้องไม่ล่มตาม
Payment Orchestrator	สั่งระบบโอนเดิม: โอนทันที / พักเงินในบัญชีผู้ซื้อ / ปล่อย / คืน ใช้ idempotency key	กันโอนซ้ำ ไม่แตะแกนระบบธนาคาร
Shipment Verifier	ตรวจเลขพัสดุกับขนส่ง	ผูกกับระบบภายนอก
Evidence Service	บันทึกทุก event แบบ append-only, hash chain ต่อดีล, Merkle root เป็นรอบแล้วเซ็นกำกับ	หลักฐานต้องแก้ย้อนหลังไม่ได้
Case/Report	สร้าง Evidence Pack (PDF + QR สำหรับตรวจ) ส่งต่อตำรวจ/1441	สร้างเฉพาะเมื่อมีการแจ้ง จึงประหยัด
Admin Console	พนักงานจัดการเฉพาะกรณีพิเศษ ทุกการกระทำต้องมีคนอนุมัติสองคน	ป้องกันคนในทุจริต

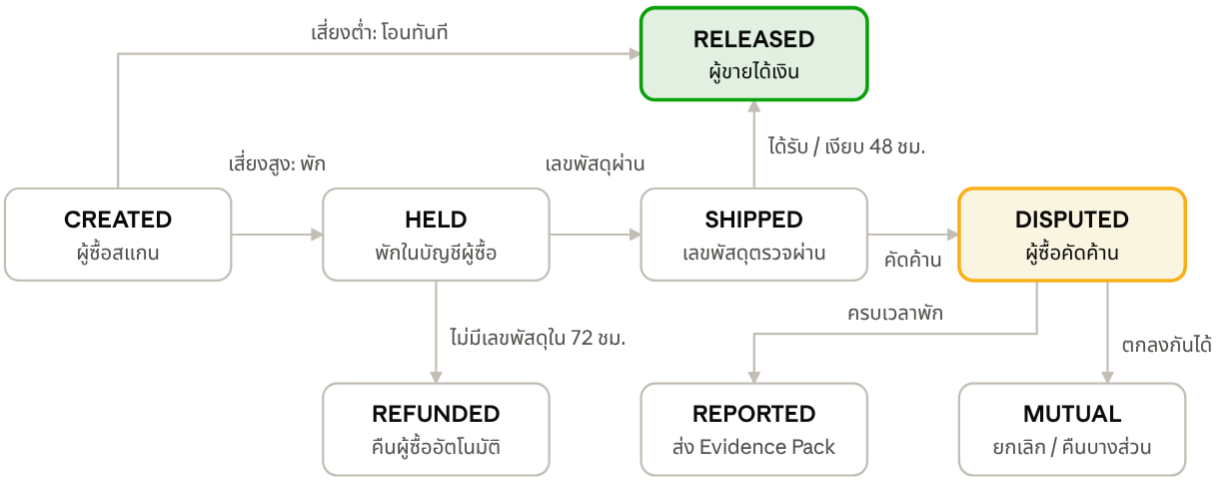
เส้นทางเร็วกับงานเบื้องหลัง

ทำตอนผู้ใช้รอ (fast path)	ทำเบื้องหลัง (async)
ตรวจลายเซ็น QR ในเครื่องผู้ใช้	คำนวณคะแนนความเสี่ยงและ graph
ค้นสถานะ QR และคะแนนจาก Redis	เรียก API ราชการ แล้ว cache ผล
สร้างดีล 1 แถว	เขียน hash chain และ Merkle root
สั่งโอนหรือพักเงิน	สร้าง Evidence Pack (เฉพาะเมื่อมีการแจ้ง)

ทุก service เป็นแบบ stateless จึงเพิ่มเครื่องได้ตามโหลด ถ้า Risk Service ล่ม ระบบแสดง **เหลือง: ตรวจไม่ได้ตอนนี้** ห้ามแสดงเขียว

สถานะของดีล (state machine)

ดีลเสี่ยงต่ำจบทันที ดีลเสี่ยงสูงปล่อยเงินเมื่อเลขพัสดุผ่านและส่งถึง



deal state machine · 8 สถานะ

ทุกทางแยกตัดสินด้วยกฎที่เครื่องตรวจได้ (คะแนนความเสี่ยง, เลขพัสดุ, เวลา) มีแค่ DISPUTED ที่ไม่ตัดสินเอง แต่ส่งหลักฐานต่อหน่วยงานรัฐ

3. User Flow

ผู้เกี่ยวข้อง: ผู้ขาย, ผู้ซื้อ, ระบบ (อัตโนมัติ), พนักงานธนาคาร (เฉพาะกรณีพิเศษ) และหน่วยงานภายนอก (ตำรวจ/AOC และขนส่ง)

ขั้น 0: คุยกันในโซเชียล

ผู้ซื้อเห็นโพสต์ใน Facebook / IG / LINE แล้วคุยต่อรองราคาในแชตตามปกติ ระบบเรายังไม่เกี่ยว ทางเข้าสำรอง: ผู้ซื้อกด **"ขอดีลที่ธนาคารรับรอง"** ส่งลิงก์ให้ผู้ขาย ผู้ขายที่ปฏิเสธก็คือสัญญาณเตือนในตัวเอง

ขั้น 1: ผู้ขายสร้างดีล

#	ผู้ขายเห็น/ทำ	ระบบทำ
1.1	กด "สร้างดีล" ใกล้เมนูรับเงิน	ตรวจด่านผู้ขาย (บัญชีไม่ถูกอายัด / ไม่ติดธงบัญชีม้า)
1.2	กรอกชื่อสินค้า, ราคา, จำนวน (1 = ชิ้นเดียว), สภาพ, ส่งภายในกี่วัน, รูป (ถ้ามี)	—
1.3	ยืนยันตัวตน: สแกนหน้าเฉพาะครั้งแรก, เครื่องใหม่ หรือยอดสูง นอกนั้นใช้ PIN	risk-based / step-up authentication

#	ผู้ขายเห็น/ทำ	ระบบทำ
1.4	ได้ QR + ลิงก์ แล้วส่งในแชต	เซ็น QR ด้วย HSM ครั้งเดียว, เก็บสถานะใน Redis, ส่ง event `LISTING_CREATED` เข้า hash chain

ผู้ขายประจำใช้ QR ร้านเดิมซ้ำได้ ไม่ต้องสร้างใหม่ทุกครั้ง

ขั้น 2: ผู้ซื้อสแกนและดูการ์ด

#	ผู้ซื้อเห็น/ทำ	ระบบทำ
2.1	เปิดแอปธนาคาร กดสแกน (ปุ่มเดิม)	แอปตรวจลายเซ็นด้วย public key ที่ฝังไว้ ในเครื่อง ไม่ต้องรอเน็ต
2.2	QR ปลอมหรือถูกแก้ → จอแดง "QR นี้ไม่ได้ออกโดยธนาคาร" จ่ายต่อไม่ได้	บันทึกความพยายามเป็นสัญญาณภัยคุกคาม
2.3	QR ของจริง →	① ตรวจสถานะ QR ② ตรวจด่านผู้ซื้อ ③ สร้างดีล (Deal ID ผูกกับผู้ซื้อคนนี้) ④ อ่านคะแนนผู้ขายจาก cache
2.4	เห็นการ์ดดีล: ชื่อจริงผู้ขาย (ปิดบางส่วน), อายุบัญชีเป็นช่วง, จำนวนดีลสำเร็จ (นับคู่ค้าไม่ซ้ำ), ระดับความเสี่ยงพร้อมเหตุผลเป็นหมวด, เงื่อนไขดีล	—

ระดับบนการ์ด

ระดับ	ปุ่มหลักที่แสดง	ผลเมื่อจ่าย
เขียว	"ยอมรับและจ่าย"	โอนให้ผู้ขายทันที
เหลือง	"ยอมรับและจ่าย" พร้อมเตือนสั้น ๆ	พักเงิน ถ้ายอดสูงเกินพฤติกรรมปกติของผู้ซื้อ
แดง	ปุ่มหลัก "ยังไม่จ่าย / เลื่อนไปก่อน" ปุ่มจ่ายเป็นปุ่มรอง ต้องรอนับถอยหลังสั้น ๆ	พักเงินเสมอ
ห้ามทำรายการ	ไม่มีปุ่มจ่าย	ตามกฎหมาย เช่น บัญชีถูกอายัด

ขั้น 3: ผู้ซื้อยืนยันและจ่าย

#	ผู้ซื้อเห็น/ทำ	ระบบทำ
3.1	กดยอมรับเงื่อนไข	บันทึก `CONTRACT_ACCEPTED` พร้อม hash ของเงื่อนไข
3.2	ยืนยันตัวตนผ่านขั้นยืนยันเดิมของแอป: เขียวยอดต่ำใช้ PIN, แดงหรือยอดสูงใช้สแกนหน้า	step-up
3.3	เห็น "จ่ายแล้ว" หรือ "จ่ายแล้ว (พักไว้ในบัญชีคุณจนกว่าเลขพัสดุผ่าน)"	Payment Orchestrator โอนหรือพักเงิน ใช้ idempotency key

ขั้น 4: ผู้ขายส่งของ

#	ผู้ขายเห็น/ทำ	ระบบทำ
4.1	ได้แจ้งเตือน "ผู้ซื้อจ่ายแล้ว (พักไว้/โอนแล้ว)" พร้อมนาฬิกา 72 ชม.	—
4.2	ถ่ายรูปหรือคลิปตอนแพ็กของในแอป (บังคับเฉพาะดีลพักเงิน)	เก็บไฟล์ใน WORM storage และนำ hash เข้า chain
4.3	ใส่เลขพัสดุ	ตรวจ: มีจริงไหม, สร้างหลังทำดีลไหม, ปลายทางตรงจังหวัดผู้ซื้อไหม, ใช้กับดีลอื่นแล้วหรือยัง
4.4	ไม่ผ่าน → ได้เหตุผลและส่งใหม่ได้ภายในเวลาเดิม	ครบ 72 ชม. ยังไม่ผ่าน → คืนเงินผู้ซื้ออัตโนมัติ

ขั้น 5: ผู้ซื้อรับของ

#	ผู้ซื้อเห็น/ทำ	ระบบทำ
5.1	ได้แจ้งเตือน "ผู้ขายส่งแล้ว (เลขพัสดุตรวจผ่าน)"	—
5.2	ขนส่งแจ้งส่งถึง → กด "ได้รับแล้ว"	ปล่อยเงินให้ผู้ขาย
5.3	เงียบเกิน 48 ชม. หลังส่งถึง	ปล่อยเงินให้ผู้ขายอัตโนมัติ
5.4	กด "คัดค้าน" ต้องเลือกเหตุผลและแนบรูป	→ DISPUTED

ขั้น 6: กรณีคัดค้าน (ธนาคารไม่ตัดสิน)

1. ระบบเปิดช่อง "ตกลงกันเอง" เช่น ยกเลิกร่วมกัน, คืนบางส่วน หรือส่งของใหม่ ตกลงได้ก็จบ
2. ตกลงไม่ได้ → เงินพักต่อได้ไม่เกินกำหนด (เช่น 7 วัน) ระบบสร้าง Evidence Pack ให้ผู้ซื้อส่งต่อ AOC 1441 / ตำรวจ

3. ครบเวลา → ผลเป็นไปตามคำสั่งอายัดของรัฐ ถ้ามี **(ถ้าไม่มีคำสั่ง เงินควรไปทางไหน ต้องถาม mentor)**

พนักงานธนาคาร

- ไม่มีสิทธิ์ย้ายเงินในดีลด้วยคนเดียว ทุกการกระทำต้องมีคนอนุมัติสองคน และเข้าจากอุปกรณ์ที่ลงทะเบียนไว้
- งานที่ทำได้: ตรวจคิวสัญญาณภัยคุกคาม (QR ปลอม, รูปแบบบัญชีม้า), ตอบคำร้องผู้ขายที่ถูกจัดระดับผิด และส่งเรื่องต่อหน่วยงานรัฐ
- ทุกการกระทำเข้า hash chain เหมือน event อื่น

4. Method ที่ใช้ในแต่ละขั้น

ขั้น	Method	ทำไม	Ref
เซ็น QR	ECDSA P-256 หรือ Ed25519	ลายเซ็นสั้น เหมาะกับ QR และตรวจในเครื่องได้เร็ว	FIPS 186-5, RFC 8032
รูปแบบข้อมูลใน QR	COSE_Sign1 (กะทัดรัดกว่า JWS) มี `kid` สำหรับหมุนเปลี่ยน key	QR มีพื้นที่จำกัด	RFC 9052, RFC 7515
เก็บ private key	HSM ระดับ FIPS 140-3	key ไม่เคยออกจากฮาร์ดแวร์	FIPS 140-3
QR ใช้ซ้ำ	QR ผู้ขาย/สินค้าใช้ซ้ำ + สร้างดีลที่เซิร์ฟเวอร์ทุกครั้งที่สแกน + ตรวจสถานะจาก Redis	เซ็นครั้งเดียว และกันการขายสินค้าชิ้นเดียวซ้ำ	ออกแบบเอง (อิงภัยคุกคามจาก Krombholz 2014)
ยืนยันตัวตน	Risk-based / step-up authentication ใช้ biometric ของแอปเดิม	ไม่เพิ่มขั้นสำหรับดีลปลอดภัย	Wiefling et al. 2019, NIST SP 800-63B
ความปลอดภัยของแอป	App attestation (Play Integrity / App Attest) ตาม OWASP MASVS	กันแอปปลอมหรือแอปที่ถูกดัดแปลง	OWASP MASVS
เรียก API ภายนอก	OAuth 2.0 client credentials + mTLS	token อายุสั้น สิทธิ์จำกัด ไม่เก็บรหัสผ่าน	RFC 6749, RFC 8705
กันกดซ้ำหรือโอนซ้ำ	Idempotency-Key	เน็ตหลุดแล้วกดใหม่ เงินต้องไม่ออกสองรอบ	IETF draft
กันยิงถล่ม	Rate limit แบบ token bucket ต่อผู้ใช้/อุปกรณ์/QR	กันสแกนวนเพื่อเดาข้อมูล	แนวปฏิบัติของ API gateway

ขั้น	Method	ทำไม	Ref
คะแนนความเสี่ยง	กฎ (rules) + gradient boosting + graph feature (GraphSAGE) ของเครือข่ายการโอน	กฎอธิบายได้, ML จับรูปแบบซ่อน, graph จับบัญชีม้าที่ทำงานเป็นเครือข่าย	XGBoost, GraphSAGE, Tare et al. 2025
แสดงเหตุผล	Reason codes เป็นหมวด ไม่บอกค่า threshold	ผู้ใช้เข้าใจ และมิจฉาชีพปรับตัวหนียาก	—
ออกแบบคำเตือน	ปุ่มหลักคือ "ยังไม่จ่าย" + คำเตือนเปลี่ยนรูปแบบได้ + แสดงเฉพาะเมื่อเสี่ยงจริง	คำเตือนเฉย ๆ ได้ผลน้อย คนชินจนมองข้าม	Akesson et al. 2023, Vance et al. 2018
พักเงิน	พักยอดในบัญชีผู้ซื้อ (earmark) + นาฬิกาใน state machine	เงินไม่ออกจากบัญชีผู้ซื้อ (สถานะทางกฎหมายต้องยืนยัน)	ต้องถาม mentor
ตรวจพัสดุ	Carrier API: ตรวจการมีอยู่, เวลาสร้าง, ปลายทาง, การใช้ซ้ำ	กฎตรวจด้วยเครื่องได้ ไม่ต้องใช้คนตัดสิน	จำลองใน demo
หลักฐาน	Hash chain (SHA-256) ต่อดีล + Merkle root เป็นรอบ เซ็นด้วย HSM + WORM storage	แก้ย้อนหลังไม่ได้ และพิสูจน์รายการเดียวได้โดยไม่ต้องเปิดทั้งหมด	Schneier & Kelsey 1999, Crosby & Wallach 2009, RFC 9162
ความเป็นส่วนตัว	Data minimization: ปิดชื่อบางส่วน, ผู้ขายไม่เห็นผลตรวจผู้ซื้อ	ตาม PDPA	พ.ร.บ.คุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562
พนักงาน	Zero Trust + RBAC + dual approval	กันคนในทุจริต	NIST SP 800-207
ความทนทาน	Circuit breaker, outbox pattern, ล่มแล้วแสดงเหลือง	ระบบภายนอกล่มต้องไม่ลากเราล่มตาม	แนวปฏิบัติ microservices
เฟส 2 ข้ามธนาคาร	Federated learning + MPC	ธนาคารแชร์สัญญาณโกงได้โดยไม่เปิดข้อมูลลูกค้า	Arora et al. 2023

5. จุดอ่อนและวิธีแก้

#	จุดอ่อน	ทำไมเป็นปัญหา	วิธีแก้
1	บัญชีใหม่ไม่มีประวัติ	ผู้ขายสุจริตที่เพิ่งเริ่มโดนเหลือง มิจฉาชีพก็ใช้บัญชีใหม่	ดีลแรก ๆ จำกัดยอดและพักเงิน ปลดเมื่อมีดีลสำเร็จกับคู่ค้าไม่ซ้ำ

#	จุดอ่อน	ทำไมเป็นปัญหา	วิธีแก้
2	บัญชีม้าที่ดูสะอาด / บัญชีผู้ขายดีถูกยึด	คะแนนจากประวัติหลอกได้	สัญญาณพฤติกรรม (เปลี่ยนเครื่อง, เพิ่งรีเซ็ตรหัส, ยอดเข้าพุ่ง) → สแกนหน้าและลดระดับชั่วคราว
3	มิจฉาชีพไม่ใช้ระบบ	ระบบเป็นแบบสมัครใจ	ทำให้ "ไม่มีดีลรับรอง" เป็นสัญญาณเตือนผ่านปุ่ม "ขอดีล" + รณรงค์ และยอมรับตรง ๆ ว่าไม่ครอบคลุม 100%
4	ส่งกล่องเปล่าด้วยเลขพัสดุจริง	เลขพัสดุพิสูจน์ได้แค่การส่ง	รูป/คลิปตอนแพ็กพร้อม hash + น้ำหนักจากขนส่ง (ถ้า API ให้) ใช้เป็นหลักฐาน ไม่ใช่ให้ธนาคารตัดสิน
5	ผู้ซื้อคัดค้านมั่วเพื่อยื้อเงิน	ผู้ขายสุจริตเสียหาย	บังคับเหตุผลและรูป, จำกัดเวลาพัก, นับสถิติการคัดค้านของผู้ซื้อ
6	ผู้ซื้อกับผู้ขายสมรู้กัน (ปั่นดีล/ฟอกเงิน)	คะแนนน่าเชื่อถือปลอม	นับเฉพาะคู่ค้าที่ไม่ซ้ำกัน และใช้ graph จับวงที่โอนวนกันเอง
7	คนชินกับคำเตือน	เตือนบ่อยจนไม่อ่าน	เตือนแรงเฉพาะสีแดง, เปลี่ยนรูปแบบคำเตือน, ใช้ปุ่ม "ยังไม่จ่าย" แทนข้อความยาว
8	จัดระดับผิด (false positive)	ผู้ขายสุจริตเสียลูกค้า	ช่องยื่นคำร้อง, แสดงเหตุผลเป็นหมวด, วัดอัตราผิดพลาดเป็น KPI
9	API ราชการช้าหรือล่ม	ผู้ใช้ต้องรอหรือระบบค้าง	cache ต่อบัญชี (เช่น 24 ชม.) + circuit breaker ล่มให้เป็นเหลือง ห้ามเป็นเขียว
10	การพักเงินอาจถูกมองว่าเป็น escrow	ธนาคารต้องขออนุญาตตาม พ.ร.บ.	แผนสำรอง: "หน่วงเวลาโอน" ที่ผู้ซื้อยกเลิกเองได้ หรือคำเตือน + Evidence Pack อย่างเดียว
11	QR ถูกแคปไปใช้ต่อ	อาจขายสินค้าชิ้นเดียวซ้ำ	ดีลผูกกับผู้ซื้อที่สแกน สินค้าชิ้นเดียว ปิดสถานะทันทีที่มีคนจ่าย
12	QR ปลอมที่ทำให้ดูเหมือนของธนาคาร	ผู้ใช้ถูกหลอกด้วยรูปลักษณ์	ตรวจได้เฉพาะในแอปจริง ลายเซ็นไม่ผ่านขึ้นจอแดงและห้ามจ่าย
13	เฟส 1 จำกัดเฉพาะธนาคารเดียว	Impact ดูเล็ก	วาง roadmap เฟส 2 ข้ามธนาคารด้วย FL + MPC
14	ไม่มีข้อมูลจริงมาฝึกโมเดล	กรรมการถามว่าคะแนนมาจากไหน	demo ใช้ชุดข้อมูลสังเคราะห์ IBM AML (Altman 2023) และบอกตรง ๆ ว่าเป็นข้อมูลจำลอง

#	จุดอ่อน	ทำไมเป็นปัญหา	วิธีแก้
15	เชื่อมกับ first jobber ไม่ชัด	ไฟล์ pitch บังคับข้อนี้	สถิติ: อายุ 20–29 เป็นกลุ่มที่โดนมากที่สุด (28%) และประชากรอายุ 21–30 ประมาณ 8.77 ล้านคน

6. Paper ที่เกี่ยวข้อง

หมวด	Paper	พบอะไร	ใช้กับส่วนไหน
A. เตือนและแทรกแซงก่อนจ่าย	Akesson, Gathergood & Quispe-Torreblanca (2023) Preventing Payments Fraud in the FinTech Era, CeDEx DP 2023-08	ปุ่ม call-to-action ที่ออกแบบใหม่ลดการถูกหลอกได้มาก คำเตือนแบบเดิมได้ผลน้อยกว่ามาก	การ์ดสีแดงที่ปุ่มหลักคือ "ยังไม่จ่าย" (ขั้น 2)
A	Vance, Jenkins, Anderson, Bjornn & Kirwan (2018) Tuning Out Security Warnings, MIS Quarterly 42(2)	คนชินกับคำเตือนเร็ว คำเตือนที่เปลี่ยนรูปแบบ (polymorphic) ช่วยชะลอได้มาก	การออกแบบคำเตือนสีแดง
A	Akhawe & Felt (2013) Alice in Warningland, USENIX Security	การศึกษาภาคสนามขนาดใหญ่พบว่าการออกแบบคำเตือนเปลี่ยนพฤติกรรมผู้ใช้ได้จริง	สนับสนุนว่าการออกแบบหน้าจอมีผล
B. จิตวิทยาของเหยื่อ	Fischer, Lea & Evans (2013) Why do individuals respond to fraudulent scam communications and lose money?, J. Applied Social Psychology	เหยื่อตอบสนองต่อรางวัลที่ดูดีเกินจริง และเชื่อสัญลักษณ์ของผู้มีอำนาจ	สไลด์ปัญหา + เหตุผลของ QR ที่ธนาคารเซ็น (สัญลักษณ์ความน่าเชื่อถือต้องมาจากธนาคาร)
C. ความน่าเชื่อถือในตลาด P2P	Mokhberi, Huang, Humbert, Obada-Obieh, Mehrabi Koushki & Beznosov (2024) Trust, Privacy, and Safety Factors … Facebook Marketplace, ACM CHI	สัมภาษณ์ผู้ใช้ 42 คน กังวลเรื่องความปลอดภัยทางการเงิน และอยากให้มีการยืนยันโปรไฟล์	ยืนยัน pain point + การแสดงชื่อจริงที่ธนาคารยืนยัน

หมวด	Paper	พบอะไร	ใช้กับส่วนไหน
C	Bolton, Katok & Ockenfels (2004) How Effective Are Electronic Reputation Mechanisms?, Management Science 50(11)	ระบบชื่อเสียงเพิ่มความไว้ใจ แต่ไม่สมบูรณ์	เหตุผลที่ไม่พึ่งแค่รีวิว ใช้ข้อมูลธนาคารร่วม
D. ตรวจจับบัญชีม้า	Tare, Rattasits, Wu & Wielewski (2025) Representation Learning on Large Non-Bipartite Transaction Networks using GraphSAGE	Graph embedding ตรวจบัญชีม้า แม่นขึ้นที่รายการบนสุด (Precision@20 +57%)	Graph feature ใน Risk Feature Pipeline
D	Altman et al. (2023) Realistic Synthetic Financial Transactions for Anti-Money Laundering Models, NeurIPS	ชุดข้อมูลธุรกรรมสังเคราะห์สำหรับฝึกโมเดล	ข้อมูลใน demo
E. ยืนยันตัวตนตามความเสี่ยง	Wiefling, Lo Iacono & Dürmuth (2019) Is This Really You?, IFIP SEC	ศึกษาระบบ RBA ที่ใช้จริง	Step-up auth (ขั้น 1.3 และ 3.2)
F. ความปลอดภัยของ QR	Krombholz et al. (2014) QR Code Security: A Survey of Attacks and Challenges for Usable Security	รวบรวมการโจมตีผ่าน QR	Threat model สไลด์ Threat Scenario
G. Log ที่แก้ไม่ได้	Schneier & Kelsey (1999) Secure Audit Logs to Support Computer Forensics, ACM TISSEC	ต้นแบบ hash chain สำหรับ log	Evidence Service
G	Crosby & Wallach (2009) Efficient Data Structures for Tamper-Evident Logging, USENIX Security	Merkle tree พิสูจน์รายการเดียวได้อย่างมีประสิทธิภาพ	เหตุผลที่ใช้ Merkle root แทน blockchain

หมวด	Paper	พบอะไร	ใช้กับส่วนไหน
H. แชร์ข้อมูลข้ามธนาคาร	Arora et al. (2023) Privacy-Preserving Financial Anomaly Detection via Federated Learning & Multi-Party Computation	ธนาคารฝึกโมเดลร่วมกันโดยไม่เปิดข้อมูล AUPRC ราว 0.6 → 0.7	Roadmap เฟส 2

7. ลงสไลด์ 3 นาที

หัวข้อที่ไฟล์บังคับ	ใช้ส่วนไหน
ปัญหาและกลุ่มเป้าหมาย	สถิติ ACSC (อายุ 20–29 โดนมากที่สุด, Facebook 74%) + paper หมวด B และ C
Solution และวิธีทำงาน	flow ขั้น 1–3 แบบย่อ (สร้างดีล → สแกน → การ์ดสี → จ่าย/พัก) + ภาพ architecture แบบง่าย
คุณค่าและผลกระทบ	ดีลปลอดภัยไม่เพิ่มขึ้น, ดีลเสี่ยงถูกพัก, มีหลักฐานพร้อมแจ้งความ + paper หมวด A + roadmap เฟส 2

คำถามถึง mentor ก่อนส่ง 30 ต.ค.

- [ ] การพักเงินในบัญชีผู้ซื้อทำได้ไหมในทางกฎหมาย
- [ ] เมื่อคัดค้านแล้วตกลงกันไม่ได้ และไม่มีคำสั่งอายัด เงินควรไปทางไหน
- [ ] API ราชการที่เรียกได้จริงคืออะไร (เช่น CFR) ตอบทันทีหรือเป็นรอบ และตรวจผู้ซื้อด้วยได้ไหม

Sources

- KBTG Kampus Hackathon 2026 — 3-minute pitch upload instructions (ไฟล์ที่ทีมได้รับ)
- Akesson et al. 2023, CeDEx
- Vance et al. 2018, MISQ
- Akhawe & Felt 2013, USENIX
- Fischer, Lea & Evans 2013
- Mokhberi et al. CHI 2024 (UBC news)
- Bolton, Katok & Ockenfels 2004
- Tare et al. 2025, arXiv
- Altman et al. 2023, NeurIPS
- Wiefling et al. 2019, arXiv

- Krombholz et al. 2014, Springer
- Schneier & Kelsey 1999
- Crosby & Wallach 2009, USENIX
- Arora et al. 2023, arXiv